Authentication

In backend engineering, authentication is the process of verifying who a user, service, or device is before granting access to a system. It answers the question: “Are you who you claim to be?”

It acts as the primary gatekeeper of an application. Authorization is separate: it determines what an authenticated user is allowed to do or see.

Core Concepts in Backend Authentication

- **Verification of identity:** The backend checks submitted credentials—such as a username and password, one-time passcode, biometric scan, or cryptographic key—against a secure database or identity provider.
- **State management:** Once a user is verified, the backend must recognize them across subsequent HTTP requests. Two common models are:
  - **Stateful (session-based):** The server creates and stores a session, then gives the client a session ID, often in an HttpOnly cookie.
  - **Stateless (token-based):** The server issues a cryptographically signed token, such as a JWT, that the client sends with each request. The server validates the signature without querying a database for every request.

Common Authentication Mechanisms

- **Username and password:** Passwords should not be stored in plain text; they are hashed using secure algorithms such as bcrypt or Argon2.
- **Token-based authentication / bearer tokens:** Access and refresh tokens are widely used in modern single-page applications and REST APIs.
- **API keys:** Static secret strings used for machine-to-machine communication, often to track or limit requests.
- **Multi-factor authentication (MFA):** Combines two or more factors: something you know (password), something you have (OTP or authenticator app), or something you are (biometrics).

- **OAuth 2.0 and OpenID Connect (OIDC):** OAuth 2.0 handles delegated authorization, while OIDC adds an authentication layer, as in “Sign in with Google.”

Authentication vs. Authorization (HTTP Status Codes)

A clear backend implementation separates these concepts, which is reflected in API responses:

- **401 Unauthorized:** Authentication failed or was missing; the server cannot verify who you are.
- **403 Forbidden:** The server knows who you are, but you do not have permission for the requested action.